Threat Hunting Report

Supply Chain Compromise via Malicious NPM Package

Executive Summary

During a proactive threat hunting exercise, evidence confirmed a software supply chain compromise involving healthchk-lib@1.0.1 on host PAW-TOM. The package deployed a malicious PowerShell post-install script that executed hidden encoded commands and established persistence through a Windows Registry Run key named Windows Update Monitor. The investigation validated the hunting hypothesis and reconstructed the attack chain from initial package installation through persistence.

Hunting Hypothesis

An attacker leveraged a compromised third-party software package to gain execution and establish persistence while evading detection. Verdict: VALIDATED.

Investigation Methodology

1. Reviewed provided IOCs. 2. Searched Splunk for package indicators. 3. Investigated PowerShell activity. 4. Identified persistence mechanisms. 5. Reconstructed attack timeline. 6. Determined scope and impact.

Key Splunk Searches and Results

Search	Purpose	Result
index=* "Windows Update Monitor"	Persistence Hunt	Registry Run Key discovered
index=* "healthchk-lib"	Package Investigation	postinstall.ps1 created on paw-tom
index=* "EncodedCommand"	PowerShell Execution	Hidden encoded PowerShell identified

Timeline of Events

Time	Event
10:58:24	healthchk-lib@1.0.1 installed by PAW-TOM\itadmin-tom
10:58:24	postinstall.ps1 created in node_modules
10:58:29	powershell.exe -NoP -W Hidden -EncodedCommand executed
10:58:29	Windows Update Monitor Run Key created
10:58:29+	Persistence established on host paw-tom

Attack Chain

healthchk-lib@1.0.1 -> postinstall.ps1 -> Hidden PowerShell -> Registry Run Key -> Persistence

Findings

Finding 1: healthchk-lib@1.0.1 functioned as the initial infection vector.
Finding 2: The package deployed a malicious post-install PowerShell script.
Finding 3: PowerShell executed with hidden and encoded parameters consistent with malware behavior.
Finding 4: Persistence was established through

HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Windows Update Monitor.
Finding 5: The hunting hypothesis was validated.

Scope of Impact

Affected Host: paw-tom
Affected User: tom@pawpress.me (PAW-TOM\itadmin-tom)

Indicators of Compromise

healthchk-lib@1.0.1
postinstall.ps1
powershell.exe -NoP -W Hidden -EncodedCommand
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Windows Update Monitor

Recommendations

Isolate PAW-TOM, remove the registry Run key, quarantine the malicious package, reset user credentials, decode the PowerShell payload, and conduct enterprise-wide IOC hunting.